従来の「境界防御モデル」の破綻 vs「ゼロトラスト・アーキテクチャ（NIST SP 800-207）」

☒ 従来の境界型防御（Castle & Moat）

前提：「社内ネットワーク（VPN 内）は全員安全」
城壁（Firewall/VPN）の外側は敵、内側は無条件に信頼する

致命的弱点：侵入後の横展開（ラテラルムーブメント）
- VPN の認証情報が盗まれると、社内全域にノーガードでアクセス可能
- 内部端末が 1 台マルウェア感染すると、周囲の機密サーバーへ侵入拡散
- テレワーク・クラウド移行により「境界線そのもの」が消失

ゼロトラスト（Never Trust, Always Verify）

核心原則：「社内外を問わず、いかなる通信も決して信頼しない」
場所（ネットワーク）ではなく、「ID・端末状態・振る舞い」で都度検証

ゼロトラストの 3 大防衛ピラー
1. **厳格なユーザー・端末認証**（Passkey / 多要素認証 / EDR 端末健全性）
2. **動的なアクセス制御**（PDP ポリシー決定点 → PEP 実行点による認可）
3. **マイクロセグメンテーション**（リソース単位で通信を孤立・暗号化）

米国 NIST SP 800-207 準拠：すべてのアクセス要求をリソース単位で検証し、最小権限を動的に付与